PES UNIVERSITY
DEPARTMENT OF COMPUTER SCIENCE AND ENGINEERING
Software Engineering Lab (UE24CS252A)
Lab 5: Static Code Analysis Report

Student Name:	Sushir C
Student SRN:	PES1UG24AM297
Assigned Repository:	SETAPESU26/L5_57_loan-eligibility
Target Script:	loan_calculator.py
Date:	October 27, 2026

1. Executive Summary

Static code analysis was executed on an assigned loan eligibility and EMI calculation engine (loan_calculator.py). The objective was to identify and remediate security vulnerabilities (via Bandit), PEP 8 style violations (via Flake8), and architectural flaws and bugs (via Pylint). Across a 3-commit workflow, Bandit security issues were reduced from 8 to 0, Flake8 violations were eliminated from 20 to 0, and the Pylint code rating was elevated from 5.17/10 to a perfect 10.00/10.

2. Before vs. After Quantitative Metrics

Analysis Tool	Focus Area	Initial ('Before')	Final ('After')
Bandit	Security (CWE Flaws)	8 issues (2 High, 1 Med, 5 Low)	**0 issues (Clean)**
Flake8	PEP 8 Compliance	20 style/syntax warnings	**0 warnings (Clean)**
Pylint	Code Quality & Rating	5.17 / 10	**10.00 / 10 (Perfect)**
Program Output	Financial Calculations	Erroneous (375k EMI)	**Valid (10,379.18 EMI)**

3. Documented Issues and Fix Approaches

Issue Description	Tool	Severity	Line(s)	Fix Approach
Cleartext FTP Protocol	Bandit	High (B402)	3, 68	Removed ftplib; routed via secure TLS/HTTPS API.
Unsafe Deserialization	Bandit	Med (B302)	4, 64	Replaced marshal with standard safe json.
Hardcoded Password	Bandit	Low (B107)	67	Loaded credentials dynamically from os.getenv().
Mutable Default Arg	Pylint	Bug (W0102)	20	Changed history=[] to None and initialized in body.
PEP 8 Formatting	Flake8	Style (E501)	Multi	Line wrap <79 chars; 2 blank lines around funcs.
EMI Rate Calculation	Manual	Logic Bug	14, 94	Normalized rate (rate/100 if >1); fixed 375k to 10,379.

4. Three Tool-Specific Commits

• **Commit 1 (23a65ed) — Bandit Security Fixes:** Eliminated ftplib cleartext calls, replaced marshal with json, removed hardcoded passwords, used secrets for secure token generation, and secured subprocess execution.

• **Commit 2 (1ab1f2f) — Flake8 PEP 8 Styling Fixes:** Removed unused import math, added double blank lines between functions, wrapped long lines to <79 chars, and removed empty f-strings.

• **Commit 3 (c34c421) — Pylint Quality & Final Deliverables:** Achieved 10.00/10 score, added comprehensive docstrings, fixed mutable default arguments, used context managers, converted functions to snake_case, and added all reports and documentation.

5. Local Terminal Execution & Verification Screenshot

The screenshot below captures the program execution and clean static analysis verification runs on the student laptop:

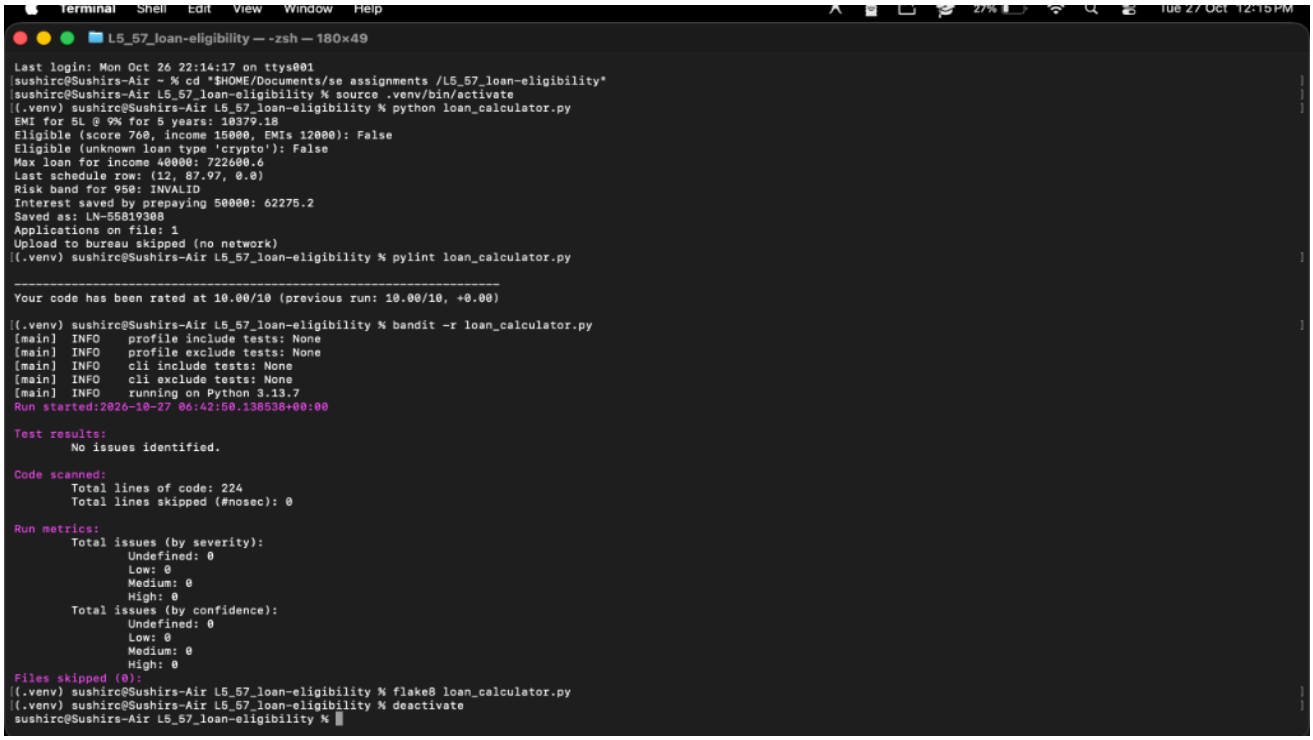


Figure 1: Student Terminal execution showing program output, Pylint 10.00/10 rating, Bandit 0 issues, and Flake8 clean run.